DevSecOps Architecture Pack

CI, Kubernetes, Runtime Detection, and Observability

1. Overview

- Security lifecycle: Plan -> Build -> Deploy -> Run -> Monitor
- Shift left, Policy as code, Least privilege, Zero trust, Observability

2. CI/CD and Build-Time Security

- Secret scanning using Gitleaks
- Dependency scanning using npm audit and Trivy
- Static analysis and linting
- Docker image build from trusted base
- Container image scanning with Trivy
- Policy checks with OPA or Conftest

3. Kubernetes Security

- Non-root containers
- Read-only root filesystem
- Resource limits and requests
- TLS ingress configuration
- Network policies for isolation

4. Runtime Detection

- Falco syscall monitoring
- Alert on abnormal behavior

5. Observability

- Prometheus metrics

- Grafana dashboards
- Alerts and reports

6. End-to-End Flow

- Developer -> CI -> Registry -> Kubernetes -> Runtime -> Monitoring

7. Portfolio Repository Map

- portfolio-frontend
- portfolio-ci-cd-security
- portfolio-daily-security
- portfolio-k8s-security
- portfolio-threat-model
- devsecops-portfolio-asad

8. Best Practices Summary

- Automate security checks
- Fail closed on critical findings
- Document controls and risks
- Harden default configurations
- Monitor continuously